Roles and Responsibilities

Who can do what in StaffSync, and where each rule is enforced

StaffSync has three roles. A user has exactly one role, assigned by HR. Nobody can pick or change their own role, and registration cannot create an HR administrator; the first HR account comes from a protected one-time setup.

Role summary

Role	Purpose	Main responsibilities
HR Administrator	Owns the people data and policies for the whole organisation.	Create, edit and deactivate employees; maintain departments; assign managers; review any leave request; publish announcements; create trainings; view organisation attendance and reports; adjust leave allocations.
Manager	Leads a team of direct reports.	View own team and its attendance; approve or reject team leave with a reason; manage trainings they created; read team reports and the team leave calendar. A manager is also an employee: checks in, applies for leave, enrolls in training.
Employee	Uses the system for own work life.	Check in and out; view own attendance; apply for, track and cancel leave; read relevant announcements; enroll in trainings; edit own name and phone; change password.

Permission matrix

Capability	HR	Manager	Employee
Log in, change own password, edit own name/phone	Yes	Yes	Yes
Create / edit / deactivate employees and invite links	Yes	No	No
View employee list	All	Own team	No
View an employee profile	Any	Own team and self	Self
Manage departments (create, edit, delete)	Yes	No	No
View department names	Yes	Yes	Yes
Check in / check out (own)	Yes	Yes	Yes
View attendance records of others	All	Own team	No
Apply for / cancel own leave	Yes	Yes	Yes
Approve or reject leave	Any except own	Direct reports only	No
View leave balances	Anyone	Self and team	Self
Adjust leave allocation (API)	Yes	No	No
Leave calendar	Organisation	Team and self	Self
Create, edit, publish, archive announcements	Yes	No	No
Read announcements meant for them	Yes	Yes	Yes
Create trainings	Yes	Yes	No
Edit, publish, archive trainings	Any	Own only	No
View training enrollees	Any	Own programs	No
Enroll in / cancel enrollment	Yes	Yes	Yes
Own notifications	Yes	Yes	Yes
Reports and analytics	Organisation	Own team	No
Dashboard	Organisation	Team	Personal

Data visibility (scope) rules

Role	Employee records	Attendance and leave	Reports
HR	Every employee	Every employee	Whole organisation, optional department filter

Role	Employee records	Attendance and leave	Reports
Manager	Users whose manager field equals the manager	Same team members (plus own records)	Team members only
Employee	Own record only	Own records only	Not available

How the rules are enforced (never only in the browser)

Layer	Mechanism	Example
Route	authenticate then authorize(role) middleware	POST /api/users allows only hr; GET /api/reports/summary allows hr and manager.
Service	Scope helper builds the list of user ids the caller may see	A manager asking for attendance of someone outside the team gets 403; list queries are forced to manager = me.
Business rule	Checks inside services	Nobody reviews their own leave; managers review only direct reports; managers edit only trainings they created.
Validation	Zod removes unknown fields	A profile update containing role: hr is silently stripped (mass assignment protection).
Front-end	ProtectedRoute and role-based menu	User experience only: hides pages the API would refuse anyway.
Database	Unique indexes and atomic updates	No duplicate check-ins, enrolments or double approvals.

Safety rules around roles

- The last active HR administrator cannot be deactivated or demoted, so the system cannot lock itself out.
- Nobody can change their own role or deactivate their own account.
- A manager must be an active user with the manager or HR role and cannot be their own manager.
- Deactivated users are rejected on their next request, even if they hold a valid cookie.
- Employees can only change name and phone; HR-controlled fields (role, department, manager, employee ID) are not editable by them.

Typical responsibilities in a normal week

Role	Daily	Weekly or as needed
HR	Check the dashboard; review pending leave; answer employee changes.	Onboard new joiners with invite links; publish announcements; open training programs; review reports.
Manager	Check in; review team status and pending approvals.	Look at the team leave calendar before approving; create team trainings; review team attendance report.
Employee	Check in and out; read notifications.	Apply for leave; enroll in trainings; keep phone number up to date.